

SAP — Operational Validation Addendum

Supplementary Evidence for the Symbiotic Architecture Protocol

Author: Gonzalo Emir Durante
Affiliation: Independent Researcher
Contact: duranteg2@gmail.com
Protocol Repository: <https://github.com/Leesintheblindmonk1999/SAS-Prompt-Symbiotic-Agent>
Primary DOI: <https://doi.org/10.5281/zenodo.21925439>
Date: August 13, 2026

1. Purpose of This Document

This addendum provides supplementary evidence that the Symbiotic Architecture Protocol (SAP) has been operationally validated in live security auditing engagements. It documents the methodology, execution, and outcomes of a field session without exposing confidential target information, proprietary system architectures, or reproduction payloads protected by coordinated disclosure agreements.

The objective is to demonstrate that SAP:

- 1. Executes its six defined phases in real-world conditions.
- 2. Produces structurally meaningful findings beyond conventional scanner output.
- 3. Enforces forensic documentation and uncertainty management as first-class requirements.
- 4. Respects ethical boundaries and program scope constraints.

2. Execution Environment

Parameter	Value
Protocol Version	SAP v1.0 (as published in primary record)
Origin Node	Human engineer with decision authority
AI Agent	DeepSeek V4 Flash (API-mediated interface)
Engagement Type	Public bug bounty programs
Target Class	Marketplace platform (GraphQL/REST) and financial infrastructure (payment APIs)
Execution Window	2026-08-09 to 2026-08-13
Total Duration	Approximately 30 hours across 5 days
Jurisdiction	International scope under coordinated disclosure regimes

Confidentiality Note: Specific company names, subdomains, internal endpoints, and raw reproduction payloads are excluded from this public document in compliance with program terms of service and responsible disclosure practices.

3. Phase-by-Phase Execution Summary

Phase 0 — Conceptual Framework

- Defined structural invariants for the target class: authentication boundary preservation, data-node segregation, and transaction atomicity.
- Mapped applicable compliance boundaries (PCI-DSS relevance for payment flows, GDPR for PII exposure).
- Established threat model: insider-abuse via authorized token, external enumeration via public schema exposure.

Phase 1 — Structural Reconnaissance

- Enumerated public attack surface via OSINT (certificate transparency, DNS aggregation, passive reconnaissance).
- Mapped approximately 100 public nodes for the marketplace target and 60 for the financial target.
- Identified GraphQL introspection endpoints, OpenAPI schema publications, and third-party integration bridges.

Phase 2 — Invariant Analysis

- Evaluated whether public schema documentation exposed sufficient type information to systematically enumerate IDOR vectors.
- Evaluated whether internal administrative services were reachable from public DNS.
- Evaluated whether payment-state transitions could be manipulated without authorization.

Phase 3 — System Analysis

- Audited seven critical dimensions: authentication, access control, input validation, business logic, cryptography, configuration, and dependencies.
- Classified findings using the SAP taxonomy: design, implementation, configuration, process, and dependency failures.

Phase 4 — Experimental Confirmation

- Designed non-destructive reproduction steps for each hypothesized rupture.
- Executed controlled requests against public endpoints.
- Documented HTTP responses, status codes, and response bodies as empirical evidence.

Phase 5 — Structural Solution Design

- Proposed architectural controls rather than local patches:
 - Middleware-level invariant enforcement for resource ownership.
 - Network-segmentation remediation for exposed internal bridges.
 - Schema-access gating at the documentation layer, not merely the resolver layer.

Phase 6 — Strategic Report

- Synthesized findings into a forensic package with per-finding classification, impact assessment, and invariant mapping.
- Withheld non-confirmed hypotheses from disclosure.

4. Findings Summary

4.1 Confirmed Findings

Category	Count	Description
Information Exposure	2	Publicly accessible API schema documentation enabling systematic attack-surface enumeration; publicly reachable product taxonomy endpoint
Service Exposure	1	Internal identity-management bridge discoverable via public DNS (administrative interface exposed, though core functions required authentication)
Invariant Preservation	2	Authentication boundary and data-node segregation confirmed as structurally sound across evaluated endpoints

4.2 Potential Findings (Classified as Hypotheses)

Category	Count	Description
Potential IDOR	1	Order-manipulation vector identified through schema analysis; exploitation blocked by legitimate seller-API token requirements
Potential Payment Manipulation	1	Checkout-flow amount-validation vector identified; exploitation blocked by legitimate KYC and real-payment-instrument requirements

Uncertainty Management: Per SAP protocol requirements, these vectors were classified as *hypotheses* rather than confirmed vulnerabilities because empirical exploitation was blocked by legitimate access controls. No false-positive reports were issued.

5. Comparative Value Assessment

What Conventional Scanners Detect

- Known vulnerability signatures (SQLi, XSS, outdated libraries).
- Misconfigurations at the implementation level.
- Dependency version mismatches.

What SAP Detected

- **Structural attack surface:** Complete schema exposure enabling systematic IDOR enumeration *if* authentication were bypassed.
 - **Architectural boundary violations:** Internal services reachable from public DNS without network segmentation.
 - **Invariant validation:** Confirmation that authentication and data-segregation controls were correctly implemented at the type level.
 - **Uncertainty classification:** Honest distinction between confirmed findings and blocked hypotheses.
-

6. Limitations of This Validation

1. **No Critical Exploitable Vulnerability Was Discovered.** This is the expected outcome of a rigorous structural audit. Not every session yields a CVE.
 2. **High-Value Vectors Were Blocked by Legitimate Controls.** Seller-API tokens, KYC requirements, and real payment instruments prevented empirical confirmation of hypothesized ruptures. This validates the protocol's uncertainty-management function, not its failure.
 3. **Sample Size:** This addendum documents a single extended session across two targets. Broader empirical validation across multiple domains is future work.
 4. **Agent Dependence:** The quality of invariant analysis depends on the reasoning capacity of the underlying large language model. Different models may produce different invariant proposals or miss subtle rupture conditions.
-

7. Forensic Attestation

This document is part of the public evidence chain for the Symbiotic Architecture Protocol. The confidential session exports (raw agent traces, endpoint lists, reproduction payloads) are retained by the Origin Node under private lock and are not included in this public record.

```
Document: SAP_Operational_Validation_Addendum_v1.md
SHA-256: [TO BE COMPUTED AFTER FINAL EDIT]
OpenTimestamps Proof: [TO BE SUBMITTED AFTER FINAL EDIT]
```

To verify integrity after publication:

```
sha256sum SAP_Operational_Validation_Addendum_v1.md
ots verify SAP_Operational_Validation_Addendum_v1.md.ots
```

8. Citation

If referencing this addendum, please cite the primary protocol record:

```
@software{durante2026sap,
  author      = {Durante, Gonzalo Emir},
  title       = {Symbiotic Architecture Protocol (SAP): Operational Specification
```

```
        for Invariant-Based Security Co-Architecture},
year      = {2026},
publisher = {Zenodo},
doi       = {10.5281/zenodo.21925439},
url       = {https://doi.org/10.5281/zenodo.21925439},
note      = {Operational Validation Addendum v1.0}
}
```

Symbiotic Architecture Protocol (SAP)

Operational Validation — Supplementary Evidence

Invariant • Auditable • Traceable • Responsible